

SECURE ENGINEERING PRINCIPLES & PLANNING

Allus AI

Document owner	Chief Technology Officer
Approval authority	Executive Management
Version	1.0
Effective date	July 1, 2026
Review cycle	At least annually and after material change

Policy statement. Allus AI integrates security into engineering decisions throughout the system life cycle. Security requirements, risks, design choices, test results, approvals, and operational lessons are considered and documented in proportion to the potential impact on customers, company operations, and protected data.

1. Purpose

This document establishes Allus AI’s guiding principles and planning requirements for engineering trustworthy, secure systems. It serves as a practical reference for product, software, cloud infrastructure, AI model, integration, and operational engineering decisions.

The objectives are to identify protection needs early, convert those needs into verifiable security requirements, reduce avoidable weaknesses, make security tradeoffs explicit, and retain evidence showing that security was considered before production release and throughout operation.

2. Scope

This standard applies to:

1. Allus AI applications, APIs, cloud infrastructure, databases, AI models, inference services, deployment tooling, and customer-facing integrations.
2. New systems and features, material architectural changes, infrastructure changes, security-sensitive configuration changes, and significant third-party dependencies.
3. The full life cycle: concept, planning, requirements, architecture, design, implementation, integration, testing, deployment, operation, maintenance, and retirement.
4. Employees and contractors who design, develop, test, deploy, administer, or materially influence in-scope systems.

The depth of documentation and review is risk-based. Routine low-risk changes may use standard tickets, pull requests, automated checks, and deployment records. Higher-risk changes require additional analysis and explicit security review as described below.

3. Reference and Alignment

This document uses NIST Special Publication 800-160 Volume 1 Revision 1, Engineering Trustworthy Secure Systems (November 2022), as guidance. In particular, it adopts the publication's life-cycle, risk-informed, requirements-driven, and evidence-based engineering perspective. The reference is used as guidance and does not, by itself, represent certification or a claim of full conformance.

Reference: <https://doi.org/10.6028/NIST.SP.800-160v1r1>

This standard also supports Allus AI's security program alignment with the SOC 2 Security Trust Services Criteria, the NIST Cybersecurity Framework, and the CIS Critical Security Controls.

4. Roles and Accountability

Security engineering is a shared responsibility with clear decision ownership:

5. Executive Management sets risk tolerance, provides resources, and accepts material residual risk when escalation is required.
6. The Chief Technology Officer owns this standard, oversees secure engineering practices, and approves or delegates approval of security-sensitive designs and releases.
7. Engineering leads ensure security requirements, risks, dependencies, testing, and operational needs are incorporated into plans and work items.
8. Engineers follow secure design and coding practices, participate in peer review, remediate identified issues, and maintain traceable implementation evidence.
9. System and change owners verify readiness for production, including testing, rollback, monitoring, access, documentation, and unresolved-risk review.
10. All personnel promptly report suspected vulnerabilities, control failures, and security events through the established incident or escalation process.

5. Guiding Secure Engineering Principles

Security by design. Security is addressed when requirements and architecture are formed, not added only at the end of development.

Risk-informed and proportionate decisions. Controls and assurance activities are selected based on assets, threats, potential loss, business impact, customer commitments, and practical constraints.

Least privilege and need-to-know. Users, services, and administrators receive only the access necessary for their authorized responsibilities, for only as long as needed.

Defense in depth. Multiple complementary safeguards are used so that failure of one control does not automatically compromise the system or protected data.

Secure defaults and minimized attack surface. Systems begin in restrictive configurations; unnecessary services, access paths, privileges, data collection, and dependencies are avoided.

Data protection throughout its life cycle. Data is protected during collection, transmission, storage, use, backup, sharing, and disposal according to sensitivity and customer obligations.

Separation and isolation. Tenant data, environments, roles, and critical functions are separated where appropriate to limit unauthorized access and the impact of failures.

Verifiable requirements and evidence. Security requirements should be stated so they can be verified through review, analysis, inspection, testing, measurement, or demonstrated operation.

Protective failure and recoverability. Systems should fail safely where practical, support containment, maintain recoverable backups, and provide tested paths to restore service.

Traceable and controlled change. Security-relevant requirements, decisions, code, infrastructure changes, test results, and approvals remain traceable through engineering records.

Secure use of third parties. Dependencies, vendors, open-source components, and services are evaluated in proportion to the access and risk they introduce and are monitored for relevant vulnerabilities.

Continuous monitoring and improvement. Operational data, vulnerabilities, incidents, audit results, customer feedback, and lessons learned are used to improve systems and engineering practices.

Shared responsibility. Allus AI secures the platform and supporting infrastructure; customers remain responsible for their user permissions, credentials, endpoints, and integration configuration unless otherwise agreed.

6. Secure Engineering Planning Process

Security planning is integrated into the normal engineering workflow. The system or change owner determines the appropriate depth of review based on data sensitivity, privilege, exposure, customer impact, recoverability, architectural significance, and the use of new technology or third parties.

11. **Define the system and context.** Identify the intended capability, users, data, trust boundaries, environments, external interfaces, dependencies, business criticality, customer obligations, and foreseeable misuse or failure conditions.
12. **Identify protection needs and security requirements.** Define confidentiality, integrity, availability, authentication, authorization, logging, isolation, encryption, retention, recovery, and assurance needs. Requirements include measurable or observable acceptance criteria where practical.

13. **Assess risk and threats.** Identify plausible threats, abuse cases, vulnerabilities, failure modes, and potential loss. Record material risks, planned treatments, owners, and residual risk. A structured threat model is required for higher-risk changes.
14. **Review architecture and design.** Evaluate trust boundaries, identity flows, data flows, secrets, interfaces, privileged functions, tenant separation, dependency risk, monitoring, failure behavior, recovery, and alternative design tradeoffs before implementation is substantially complete.
15. **Plan secure implementation.** Break requirements and risk treatments into traceable work items. Define coding, configuration, dependency, environment, access, testing, deployment, rollback, monitoring, and documentation expectations.
16. **Implement with controlled change.** Use version control, peer review, automated testing, dependency scanning, secure configuration, managed secrets, and approved deployment mechanisms. Production access and changes remain restricted and logged.
17. **Verify and validate.** Confirm the solution satisfies functional and security requirements through an appropriate combination of review, analysis, automated tests, inspection, vulnerability scanning, integration testing, and targeted manual security testing.
18. **Approve and release.** Before production, confirm that required reviews and tests passed, critical issues were resolved or formally accepted, monitoring and rollback are ready, documentation is current, and the authorized owner approved deployment.
19. **Operate, monitor, and maintain.** Monitor security-relevant events and service health, manage vulnerabilities and patches, review access, investigate anomalies, preserve logs, and incorporate operational findings into future changes.
20. **Retire securely.** When a system or component is retired, remove access and secrets, preserve required records, address customer and retention obligations, securely dispose of data where authorized, and decommission infrastructure and integrations.

6.1 Changes Requiring Enhanced Security Review

A structured threat model and explicit security review are required when a change materially introduces or affects one or more of the following:

21. Authentication, authorization, privileged access, administrative functions, secrets, or cryptographic controls.
22. Customer or sensitive data collection, use, isolation, retention, export, deletion, or cross-boundary transfer.
23. Internet-facing services, new APIs, remote connectivity, customer integrations, or significant changes to trust boundaries.

- 24. AI model training or inference data flows, model access, tenant separation, or the use of customer data.
- 25. New cloud services, deployment patterns, major infrastructure components, high-impact dependencies, or third parties with access to protected data or production systems.
- 26. Material changes to logging, monitoring, backups, disaster recovery, or the ability to contain and recover from failure.

6.2 Minimum Planning Questions

- 27. What assets, customer commitments, and business capabilities require protection?
- 28. Who or what should have access, and what is the minimum privilege required?
- 29. Where does data enter, move, persist, and leave the system?
- 30. What trust boundaries, external dependencies, and failure points exist?
- 31. How could the feature be misused, bypassed, or cause unauthorized disclosure, alteration, or service disruption?
- 32. What preventive, detective, responsive, and recovery controls are appropriate?
- 33. How will each material security requirement be tested or otherwise verified?
- 34. What logs, alerts, rollback steps, recovery procedures, and operational ownership are required?
- 35. What risks remain, who owns them, and who has authority to accept them?

7. Required Engineering Records and Evidence

Records may be maintained in tickets, repositories, pull requests, architecture documents, test systems, security tools, deployment platforms, monitoring systems, or other approved systems. Evidence should be proportionate to risk and sufficient to reconstruct the decision and demonstrate completion.

Life-cycle stage	Typical retained evidence
Initiation and planning	System/change description; scope; owner; data and dependency identification; security impact or risk classification.
Requirements	Security and privacy requirements; customer or contractual constraints; verification or acceptance criteria.
Risk and design	Risk assessment or threat model when required; architecture or design review; security decisions and tradeoffs; risk treatment actions.
Implementation	Change ticket; source and infrastructure version history; peer-review record; dependency and configuration changes; linkage to requirements or risks where applicable.
Verification	Automated and manual test results; vulnerability or dependency scan results; remediation evidence; validation of logging, access, rollback, and recovery as applicable.

Life-cycle stage	Typical retained evidence
Release	Approval record; production deployment record; unresolved-risk decision; rollback readiness; operational documentation.
Operations and maintenance	Monitoring and audit logs; vulnerability tickets; patch and change records; access reviews; backup/recovery evidence; incident and corrective-action records.
Retirement	Decommission record; access and secret removal; data retention/disposal decision; customer notification or transition evidence when applicable.

8. Baseline Secure Engineering Practices

8.1 Infrastructure and Network Security

- 36. Allus AI uses AWS-hosted, isolated cloud environments, private VPC architecture, firewall protection, HTTPS/TLS, and cloud-native DDoS mitigation.
- 37. Infrastructure changes are documented, reviewed, tested as appropriate, and deployed through controlled processes.
- 38. Production environments and administrative interfaces are restricted to authorized personnel and services.

8.2 Identity and Access Management

- 39. Role-based access control, least privilege, and separation of responsibilities are applied according to system need.
- 40. Multi-factor authentication is required for administrative accounts, supported by strong password practices and immediate access revocation during offboarding.
- 41. Privileged and security-relevant access is logged and reviewed according to risk.

8.3 Encryption and Secrets

- 42. TLS 1.2 or higher protects data in transit, and AES-256 encryption protects data at rest, including databases and backups.
- 43. Credentials, keys, tokens, and other secrets are not embedded in source code and are stored and distributed using approved protected mechanisms.
- 44. Cryptographic choices and key access are reviewed when new data flows or high-impact changes are introduced.

8.4 Customer Data and Tenant Protection

- 45. Customer data is logically isolated between tenants, and access is limited to authorized personnel for approved support and maintenance activities and is logged.

- 46. Data collection and retention are limited to legitimate business, contractual, and operational needs.
- 47. Customer data is not used to train shared foundation models without explicit authorization.

8.5 Application and Software Security

- 48. Changes use version control, peer code review, automated testing, dependency vulnerability scanning, secure change management, and controlled production deployments.
- 49. Input handling, authorization, error behavior, logging, dependency risk, and secure configuration are considered during design and review.
- 50. Critical or high-risk findings are resolved before release unless residual risk is explicitly accepted by authorized management.

8.6 Vulnerability Management

- 51. Allus AI uses continuous dependency scanning, infrastructure monitoring, patch management, and prioritized remediation of critical vulnerabilities.
- 52. Findings are evaluated based on severity, exploitability, exposure, affected assets, customer impact, and available compensating controls.
- 53. Remediation actions are tracked to closure, with exceptions handled through the risk-acceptance process.

8.7 Logging, Monitoring, and Incident Readiness

- 54. Audit logs cover authentication, administrative actions, infrastructure changes, and security events, with ongoing monitoring appropriate to system risk.
- 55. Systems are designed to support investigation, containment, recovery, and customer notification where applicable.
- 56. Security events and control failures feed the documented incident-response and corrective-action processes.

8.8 Resilience and Business Continuity

- 57. Automated backups, disaster recovery procedures, infrastructure redundancy where practical, and periodic recovery-procedure review support availability and recoverability.
- 58. Designs consider safe failure, rollback, restoration dependencies, recovery objectives, and the operational ownership needed to restore service.

8.9 Employee and Endpoint Security

- 59. Personnel receive security-awareness and phishing training.

- 60. Company devices use encryption, automatic updates, endpoint protection, and screen-lock enforcement.
- 61. Engineering access from endpoints is restricted according to role and operational need.

8.10 AI Model and Inference Security

- 62. Access to model infrastructure is controlled; manufacturing data is handled securely; tenants are separated; inference services are monitored; and deployments are version controlled.
- 63. Model and data changes are evaluated for unauthorized data use, cross-tenant exposure, integrity risks, service abuse, and operational impact.
- 64. Model releases follow the same review, test, deployment, monitoring, rollback, and evidence expectations as other production changes.

9. Security Testing and Release Criteria

Testing is selected based on risk and may include:

- 65. Peer review of code, infrastructure-as-code, configuration, access rules, and security-sensitive logic.
- 66. Unit, integration, regression, authorization, negative-path, and tenant-isolation testing as applicable.
- 67. Dependency, vulnerability, secret, container, or infrastructure scanning where supported by the relevant technology.
- 68. Targeted manual security testing or penetration testing when exposure, customer requirements, architectural significance, or risk warrants it.
- 69. Validation of security logging, alerts, backup/restore, rollback, failure handling, and operational documentation where relevant.

A production release is acceptable when:

- 70. Required reviews and tests have completed with results retained.
- 71. Known critical vulnerabilities are remediated; other material findings have documented treatment plans or authorized risk acceptance.
- 72. Access, secrets, configuration, monitoring, rollback, and recovery expectations are satisfied.
- 73. The release is approved through the established change-management process.

10. Security Tradeoffs, Exceptions, and Risk Acceptance

Engineering decisions may involve competing security, reliability, usability, performance, schedule, and cost constraints. Material tradeoffs must be explicit and must not silently bypass this standard.

An exception or risk-acceptance record must include:

- 74. The affected requirement or practice and the business or technical reason for the exception.
- 75. The systems, data, customers, and time period affected.
- 76. The risk and potential consequences, including relevant threats and exposure.
- 77. Compensating controls, remediation plan, accountable owner, and target date where applicable.
- 78. Approval by the system owner and escalation to the Chief Technology Officer or Executive Management when the residual risk is material.

Exceptions are time-bound where practicable and are reviewed when conditions change, a triggering event occurs, or the approved period expires.

11. Measurement and Continuous Improvement

Allus AI reviews security-engineering performance using available, proportionate measures, including:

- 79. Completion of required peer, design, security, and release reviews.
- 80. Open and overdue vulnerability findings, remediation priority, and time to resolution.
- 81. Security-related deployment failures, rollbacks, incidents, control exceptions, and recurring causes.
- 82. Dependency and patch status; administrative access and offboarding performance; and backup or recovery test results.
- 83. Audit findings, customer security feedback, lessons learned, and progress on corrective or preventive actions.

Results are used to improve engineering standards, training, automation, architecture, monitoring, test coverage, and risk treatment. Material issues are communicated to management through the established security and management-review processes.

12. Training, Compliance, and Review

Personnel with engineering or production responsibilities receive security guidance appropriate to their role and are expected to follow this standard. Failure to follow the standard may require remediation, additional review, access restriction, corrective action, or management escalation.

The Chief Technology Officer reviews this document at least annually and after significant changes to the business, technology, threat landscape, legal or contractual requirements, audit findings, or material security events. Updates are version controlled and communicated to affected personnel.